Gmail **Reinaldo @KeyOpinionLeaders <reinaldo@keyopinionleaders.com>**

keyopinionleaders.com Web Crawling report [AKAM-CASE #F-CS-8050923] | Sev 3 | INFORMATIONAL | Possible DDOS attack on Origin hostname

Akamai | Privacy <privacy@akamai.com> Wed, Jan 31, 2024 at 4:56 PM
To: "Reinaldo @KeyOpinionLeaders" <reinaldo@keyopinionleaders.com>
Cc: "Pare, Christina" <cpare@akamai.com>, "Hoard, Chris" <choard@akamai.com>, "Quach, Donald" <dquach@akamai.com>

Greetings Reinaldo,

My name is Jim Casey and I am VP & Chief Privacy Officer at Akamai. I was notified of your concerns regarding the potential sharing of confidential information (specifically 4 /24 IP ranges) with a third party. I have researched this with the relevant teams and wanted to provide a response to some of the matters raised.

As I understand events, Key Opinion Leaders (KOL) reported suspicious traffic to Akamai on 28 January 2024. Shortly thereafter, Akamai informed KOL that the suspicious traffic originated from a a known security researcher (a customer of Akamai's Compute services (formerly Linode)). The abuse team then requested a list of IP addresses that it could provide to the security researcher so that the researcher could remove these IP addresses from its scanning infrastructure (initiate a block). KOL then provided four /24 IP ranges (1012 usable IPv4 addresses) which the team provided to the researcher with instructions that they be added to their block list. The researcher promptly confirmed compliance.

First, I want to respond to your concern that this raises privacy issues under California Privacy laws. IP address can be considered personal information under California law if they can be used to identify an individual person or household. The IP addresses of your company's website origins would not be deemed personal information under the law as they do not relate to an individual or household, but rather identify a corporate machine on the internet. Also, the ranges provided include over a thousand IP addresses, and so clearly do not identify any individual even if they otherwise were associated with individual persons and not a company.

You also raised the issue of sharing confidential information without consent that put KOL at risk. As noted above, KOL provided the IP ranges for the purpose of putting blocking in place. I apologize if the request was not clear with respect to that blocking, but this procedure is consistent with standard process and policy for dealing with concerns raised regarding security researchers. Therefore, we do not believe that there was any improper sharing of information in this case. Also, we do not have any reason to believe that the information shared puts you at risk with this security researcher. It is unclear to me whether the entire IP ranges provided actually are assigned to KOL, just to be clear, the abuse team did not identify specific origin IP addresses, but only the subnet ranges provided by KOL. If you are continuing to see unwanted traffic to your origins, we would, of course, be happy to assist in determining the source of such traffic and how to deal with it.

At your request we did reach out to the security researcher and they invite you to learn more about their work by going to their website at https://hunt.io/about, or contacting them at contact@hunt.io.

I hope that this information alleviates at least some of your concern. Please feel free to contact me if you have any further questions or concerns.

Best Regards

Jim

James A Casey
Vice President & Chief Privacy Officer



From: "Reinaldo @KeyOpinionLeaders" <reinaldo@keyopinionleaders.com>
Date: Wednesday, January 31, 2024 at 4:13 PM
To: "Quach, Donald" <dquach@akamai.com>
Cc: Noah Hollander <noah@mobilerider.com>, Mark Frederick <fred@mobilerider.com>, support <support@akamai.com>, "abuse@linode.com" <abuse@linode.com>, "Hoard, Chris" <choard@akamai.com>, "chris@mobilerider.com" <chris@mobilerider.com>, "Pare, Christina" <cpare@akamai.com>, "Rojas, Dave" <dar@akamai.com>, "Olasso, Fio" <folasso@akamai.com>, "Yu, John" <joyu@akamai.com>, mobileriderteam <mobileriderteam@akamai.com>, "Thornburg, Austin" <mthornbu@akamai.com>, "Hayden, Patrick" <phayden@akamai.com>, Akamai | Privacy <privacy@akamai.com>, "privacy@linode.com" <privacy@linode.com>, "scott@mobilerider.com" <scott@mobilerider.com>
Subject: Re: [EXTERNAL] Re: keyopinionleaders.com Web Crawling report [AKAM-CASE #F-CS-8050923] | Sev 3 | INFORMATIONAL | Possible DDOS attack on Origin hostname

[Please excuse brevity and typos, typing from my phone]

Hi Donald, thank you for the prompt response, Please see inline,

On Wed, Jan 31, 2024 at 2:40 PM Quach, Donald <dquach@akamai.com> wrote:

> Hi Reinaldo,
>
> I wanted to check/confirm from the technical side –

1. Are you still under attack? On our end, we dont have visibility into your origin server stats to confirm.

Need to ask the team about the current status, but the concern is that the attackers now know our IP ranges because they were disclosed to them without our consent, by Akamai personnel. Regardless of current situation (whether there is an attack at the moment or not), this leak of our IP ranges:

1) Puts us at risk

2) The disclosure of our confidential IP ranges to the attackers, was a violation of Akamai's privacy policy.

We ask for the implementation of remediatory measures that hide our IPs.

1. Speaking with Mobile Rider, I believe it was shared they assisted with implementing Origin IP ACL – this provides you with a list of akamai ip ranges to whitelist at origin as these ranges are for CDN Delivery. Can you kindly confirm this is implemented and you have this whitelist enabled (Is your origin now enforcing a whitelist?)

Yes. But just so you know, this is not a real protection. There is a way to circumvent the ACLs. Here is how:

Step 1) The attacker creates a "new" property in akamai, sets any of our public IPs as "origin server" of their fake property

Step 2) The attacker hits this fake property they created that goes to our origin.

Result: Our origin servers see the requests' IPs coming from one of Akamai's ACL IPs even though the requests are really being generated by the attacker, not real users.

So the attacker, as long as they are an Akamai's customer, can circumvent the ACL simply by creating a fake property. We don't think the ACL is a real protection, especially knowing they already attacked our origin servers using Akamai/Linode infrastructure. They must already know about the way described above to circumvent the ACL.

1.

There are quite a few parties on this thread which are all looking into your other queries currently, wanted to make sure the technical front is mitigated.

Donald

From: "Reinaldo @KeyOpinionLeaders" <reinaldo@keyopinionleaders.com>
Date: Wednesday, January 31, 2024 at 12:07 PM
To: Noah Hollander <noah@mobilerider.com>
Cc: Mark Frederick <fred@mobilerider.com>, support <support@akamai.com>, "abuse@linode.com" <abuse@linode.com>, "Hoard, Chris" <choard@akamai.com>, "chris@mobilerider.com" <chris@mobilerider.com>, "Pare, Christina" <cpare@akamai.com>, "Rojas, Dave" <dar@akamai.com>, "Quach, Donald" <dquach@akamai.com>, "Olasso, Fio" <folasso@akamai.com>, "Yu, John" <joyu@akamai.com>, mobileriderteam <mobileriderteam@akamai.com>, "Thornburg, Austin" <mthornbu@akamai.com>, "Hayden, Patrick" <phayden@akamai.com>, Akamai | Privacy <privacy@akamai.com>, "privacy@linode.com" <privacy@linode.com>, "scott@mobilerider.com" <scott@mobilerider.com>
Subject: Re: [EXTERNAL] Re: keyopinionleaders.com Web Crawling report [AKAM-CASE #F-CS-8050923] | Sev 3 | INFORMATIONAL | Possible DDOS attack on Origin hostname

Moving dfhine@vorys.com to BCC

I understand. In this case, we ask MobileRider/Akamai/Lionode to please keep this thread closed and confidential, restricting it to only direct employees of companies we have signed agreements with.

We appreciate your understanding, Mr. Hine,

Thank you,

On Wed, Jan 31, 2024 at 2:00 PM Hine, David F. <dfhine@vorys.com> wrote:

> Reinaldo,
>
> Thanks for your email. I appreciate you wanting to maintain the confidentiality of corporate information. Indeed, I feel the same way about protecting my firm's information. To that end, unless there is an actual ethical conflict created by my representation of Mobile Rider, it is not really appropriate for me to answer questions about my firm's representation of other clients. That was why I was asking about the nature of your relationship with the entities you've listed below—I need to determine whether my (or Vorys's) involvement would create an ethical conflict. If you can provide that information, I can run an appropriate conflict check to vet the same.
>
> Thanks,

Dave

David F. Hine

(he/him)

Vorys, Sater, Seymour and Pease LLP

301 East Fourth Street

Ste 3500, Great American Tower

Cincinnati, Ohio 45202

Direct: 513.723.4078

Cell: 513.404.4991

Fax: 513.852.7833

Email: dfhine@vorys.com

www.vorys.com